Room - Gobuster: The Basics

What is Gobuster?

Gobuster is a tool used in cybersecurity to **find hidden resources** on a system.

- It is written in **Go (Golang)**
- It is commonly used in:
  - Penetration testing
  - Bug bounty hunting
  - Security assessments

Think of it like a **scanner that tries to discover things that are not directly visible**.

Where does Gobuster fit in Ethical Hacking?

Ethical hacking has phases:

1. Reconnaissance (information gathering)
2. Scanning (finding vulnerabilities)

Gobuster works **between these two phases**:

- It **collects hidden information**
- Then helps in **finding possible attack points**

Key Concepts You Mentioned

1. Enumeration (Very Important)

Definition:
Enumeration means **listing everything that exists**, whether you can access it or not.

Example:

Suppose a website exists:

example.com

You only see:

example.com/home

But Gobuster can find hidden directories like:

example.com/admin
example.com/login
example.com/backup

Even if they are hidden, Gobuster **lists them**.

So:

Enumeration = “Find and list all possible resources”

2. Brute Force (Core Idea)

Definition:
Brute force means **trying all possible options until something works**.

Simple Analogy:

You have 10 keys
You try each key in a lock
One key will open it.

That’s brute force.

How Gobuster Uses These Concepts

Gobuster combines both ideas:

Step-by-step:

1. It takes a **wordlist** (a list of possible names)

   admin
   login
   dashboard
   backup
   test

2. It **adds each word to a website URL**

example.com/admin
example.com/login
example.com/dashboard

3. It sends requests to each URL
4. It checks responses:
    - 200 → Exists
    - 404 → Not found

What Gobuster Can Find

Gobuster can enumerate:

- Web directories → `/admin`, `/uploads`
- DNS subdomains → `mail.example.com`
- Virtual hosts → different hidden websites
- Cloud storage → AWS S3, Google Cloud buckets

Simple One-Line Understanding

Enumeration = Listing everything
Brute Force = Trying all possibilities
Gobuster = Uses brute force to perform enumeration

```
root@tryhackme:~# gobuster --help
Usage:
  gobuster [command]

Available Commands:
  completion  Generate the autocompletion script for the specified shell
  dir         Uses directory/file enumeration mode
  dns         Uses DNS subdomain enumeration mode
  fuzz        Uses fuzzing mode. Replaces the keyword FUZZ in the URL, Headers and the request body
  gcs         Uses gcs bucket enumeration mode
  help        Help about any command
  s3          Uses aws bucket enumeration mode
  tftp        Uses TFTP enumeration mode
  version     shows the current version
  vhost       Uses VHOST enumeration mode (you most probably want to use the IP address as the URL parameter)

Flags:
      --debug               Enable debug output
      --delay duration      Time each thread waits between requests (e.g. 1500ms)
  -h, --help                help for gobuster
      --no-color            Disable color output
      --no-error            Don't display errors
  -z, --no-progress         Don't display progress
  -o, --output string       Output file to write results to (defaults to stdout)
  -p, --pattern string      File containing replacement patterns
  -q, --quiet               Don't print the banner and other noise
  -t, --threads int         Number of concurrent threads (default 10)
  -v, --verbose             Verbose output (errors)
  -w, --wordlist string     Path to the wordlist. Set to - to use STDIN.
      --wordlist-offset int Resume from a given position in the wordlist (defaults to 0)
```

```
gobuster dir -u "http://www.example.thm/" -w /usr/share/wordlists/dirb/small.txt -t 64
```

- `gobuster dir` indicates that we will use the directory and file enumeration mode.
- `-u "http://www.example.thm/"` tells Gobuster that the target URL is http://example.thm/.
- `-w /usr/share/wordlists/dirb/small.txt` directs Gobuster to use the *small.txt* wordlist to brute force the web directories. Gobuster will use each entry in the wordlist to form a new URL and send a GET request to that URL. If the first entry of the wordlist were images, Gobuster would send a GET request to http://example.thm/images/.
- `-t 64` sets the number of threads Gobuster will use to 64. This improves the performance drastically.

Now that we have a quick overview of Gobuster, let's explore the different modes and their use cases in the following tasks.

🔹 What is “dir mode”?

Gobuster has a **dir mode**:

👉 It is used to:

- Find **directories**
- Find **files inside directories**

Example structure:

```
wordpress/
├── wp-admin
├── wp-content
├── wp-includes
```

Gobuster can discover such folders using brute force

🔹 Simple Example Command

gobuster dir -u http://example.com -w wordlist.txt

- `dir` → directory scanning mode
- `-u` → target website
- `-w` → wordlist

🔹 Important Point

❗ Gobuster does NOT guess randomly
✔ It uses **common patterns + wordlists**
✔ Many websites follow similar naming (like admin, login)

🔹 Final Clear Understanding

👉 Gobuster =
Uses brute force (trying many names)
➡️ To perform enumeration (listing hidden resources)

What is DNS Mode in Gobuster?

DNS mode is used to **find subdomains** of a website.

👉 A **subdomain** is a smaller part of a main domain.

Example:

If main domain is:

example.com

Subdomains can be:

www.example.com
mail.example.com
shop.example.com
admin.example.com

🔹 Why is it Important?

Even if the main website is secure, **subdomains may not be secure**.

👉 Example:

- `example.com` → secure ✅
- `mobile.example.com` → may have vulnerability ❌

✔ Attackers (or ethical hackers) check subdomains to find weak points.

🔹 How Gobuster DNS Mode Works

Step 1: Take a wordlist

Example wordlist:

www
mail
shop
admin
blog

Step 2: Add each word before domain

If domain is:

example.com

Gobuster tries:

www.example.com
mail.example.com
shop.example.com
admin.example.com

Step 3: Send DNS requests

Gobuster asks:
👉 “Does this subdomain exist?”

Step 4: Check response

- If exists → show it ✅
- If not → ignore ❌

🔹 Example Command

gobuster dns -d example.com -w wordlist.txt

Meaning:

- `dns` → DNS mode
- `-d` → domain name
- `-w` → wordlist

🔹 Example Output (What You Saw)

Found: www.example.com
Found: shop.example.com
Found: academy.example.com
Found: primary.example.com

👉 This means:
Gobuster **successfully found valid subdomains**.

🔹 Important Flags (Simple)

- `-d` → target domain
- `-w` → wordlist
- `-i` → show IP address
- `-c` → show CNAME info
- `-r` → use custom DNS server

🔹 Key Idea

👉 DNS mode =
Uses brute force (trying names)
➡️ To find subdomains (enumeration)

🔹 What is VHOST Mode in Gobuster?

👉 **VHOST mode is used to find hidden websites (virtual hosts) on the same server.**

🔹 First Understand This (Very Important)

🌐 One server → Many websites

A single server (same IP) can host **multiple websites**.

👉 These are called **Virtual Hosts (VHOSTs)**

Example:

- `example.com`
- `blog.example.com`
- `shop.example.com`

All may run on **same IP**, but are **different websites**

🔹 Difference: DNS vs VHOST (Important for Exams)

Feature	DNS Mode	VHOST Mode

How it works	Uses DNS lookup	Uses HTTP request
What it finds	Subdomains	Virtual hosts (hidden sites)
Example	`blog.example.com` exists in DNS	Server responds differently based on host

👉 Simple:

- **DNS → asks "Does this domain exist?"**
- **VHOST → asks "Does server respond to this host?"**

🔹 How VHOST Mode Works

Step 1: Take a wordlist

www
blog
shop
admin

Step 2: Create hostnames

www.example.com
blog.example.com
shop.example.com

Step 3: Send HTTP request

Gobuster sends request like:

Host: blog.example.com

👉 It changes the **Host header** each time

Step 4: Check response

- If valid → FOUND ✅

- If not → ignore ❌

🔹 Example Command

gobuster vhost -u http://IP -w wordlist.txt --domain example.com --append-domain

---

🔹 Meaning of Important Flags

- `-u` → target URL (IP or domain)
- `-w` → wordlist
- `--domain` → main domain (example.com)
- `--append-domain` → makes `word.example.com`
- `--exclude-length` → removes false results

🔹 Example Output

Found: blog.example.com
Found: shop.example.com
Found: www.example.com

👉 These are **valid virtual hosts** found on the server.

🔹 Important Concept (Very Important)

👉 Gobuster **does NOT use DNS here**

✔ Instead, it:

- Sends HTTP requests
- Changes `Host:` header
- Checks how server responds

🔹 Why This Matters

Sometimes:

- DNS may not show a subdomain ❌
- But server still has a hidden website ✅

👉 VHOST mode helps find those hidden sites

🔹 Final Simple Understanding

👉 VHOST mode =
Uses brute force (wordlist)
➡️ Changes Host header
➡️ Finds hidden websites on same server